

VULNERABILITY ASSESSMENT REPORT

Target Application: Altoro Mutual (testfire.net)

Prepared By: Lemina K

Role: Cyber Security Intern

Organization: Future Interns

Date: April 2026

Introduction

This report presents the findings of a vulnerability assessment conducted on the Altoro Mutual web application (testfire.net).

The assessment was performed using a black-box approach with a focus on identifying common security weaknesses through passive and ethical testing methods.

The purpose of this report is to highlight potential risks, explain their impact in simple terms, and provide practical recommendations to improve the overall security posture of the application.

Objective

The objective of this assessment is to evaluate the security of the target web application and identify potential vulnerabilities.

This includes:

- Detecting exposed services
- Identifying missing security protections
- Analyzing configuration weaknesses

The goal is to provide a clear and structured report that helps improve application security.

Scope

- Target: <http://testfire.net/>
- Public-facing pages only
- No authentication or login bypass attempted
- Passive testing techniques only

Methodology

1. Reconnaissance using Nmap
2. Passive vulnerability scanning using OWASP ZAP
3. Security header and cookie analysis using browser DevTools
4. Documentation and risk classification

Network Scan Findings (Nmap)

FINDING	RISK LEVEL	DESCRIPTION	IMPACT	REMEDIATION
Open HTTP Port (80)	Medium	Port 80 (HTTP) is open and accessible	Data is transmitted without encryption	Enforce HTTPS and redirect HTTP traffic
Server Information Disclosure	Low	Server reveals "Apache-Coyote" details	Helps attackers identify vulnerabilities	Hide server version information

FIGURE 1: NMAP SCAN RESULTS SHOWING OPEN PORTS

```
(root@kali)-[/home/kali]
# nmap -sV testfire.net
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-13 11:44 EDT
Nmap scan report for testfire.net (65.61.137.117)
Host is up (0.32s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache Tomcat/Coyote JSP engine 1.1
443/tcp   open  ssl/http     Apache Tomcat/Coyote JSP engine 1.1
8080/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
8443/tcp  closed https-alt

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 53.19 seconds
```

FIGURE 2: RESULTS SHOWING SERVER INFORMATION EXPOSURE

```
(root@kali)~[/home/kali]
# nmap -A testfire.net
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-13 11:48 EDT
Nmap scan report for testfire.net (65.61.137.117)
Host is up (0.29s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
80/tcp    open  tcpwrapped
|_http-server-header: Apache-Coyote/1.1
|_http-title: Altoro Mutual
443/tcp    open  ssl/http     Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Altoro Mutual
|_ssl-cert: Subject: commonName=demo.testfire.net
| Subject Alternative Name: DNS:demo.testfire.net
| Not valid before: 2025-05-21T00:00:00
|_Not valid after: 2026-06-21T23:59:59
|_ssl-date: 2026-04-13T15:49:07+00:00; 0s from scanner time.
8080/tcp   open  http         Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Altoro Mutual
|_http-server-header: Apache-Coyote/1.1
8443/tcp   closed https-alt
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2008|7|2016|10 (92%), FreeBSD 6.X (85%)
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_8 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows_server_2016 cpe:/o:freebsd:freebsd:6.2 cpe:/o:mi
s_10
Aggressive OS guesses: Microsoft Windows Server 2008 R2 or Windows 8 (92%), Microsoft Windows Server 2008 R2 or Windows 7 SP1 (89%), Microsoft Windows Server 2008 R2 SP1 or Win
Microsoft Windows 7 or Windows Server 2008 R2 (87%), Microsoft Windows Server 2016 (87%), Microsoft Windows Server 2008 R2 (86%), FreeBSD 6.2-RELEASE (85%), Microsoft Windows
, Microsoft Windows Server 2008 R2 SP1 (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 13 hops

TRACEROUTE (using port 8443/tcp)
HOP RTT      ADDRESS
1   5.12 ms  192.168.220.1
2   ...
3   8.17 ms  keralavisionisp-dynamic-5.160.199.103.keralavisionisp.com (103.199.160.5)
4   28.77 ms 122.184.141.49
5   62.42 ms 116.119.42.17
6   62.56 ms 63-218-107-193.static.as3491.net (63.218.107.193)
7   279.21 ms be41.br04.dal01.as3491.net (63.218.22.246)
8   ... 9
10  277.25 ms cored-dcpe4.dfw1.rackspace.net (148.62.41.99)
11  271.69 ms core10-corec.dfw1.rackspace.net (148.62.41.123)
12  275.11 ms core10-aggr171a-8.dfw3.rackspace.net (74.205.108.69)
13  282.14 ms 65.61.137.117

OS and Service detection performed. Please report any incorrect
Nmap done: 1 IP address (1 host up) scanned in 69.79 seconds
```

Vulnerability Findings (OWASP ZAP)

VULNERABILITY	RISK LEVEL	DESCRIPTION	IMPACT	REMEDIATION
Absence of Anti-CSRF Tokens	Medium	Application does not include CSRF protection	Attackers can perform actions on behalf of users	Implement anti-CSRF tokens in forms
Missing Content Security Policy (CSP)	Medium	CSP header is not set	Increased risk of XSS attacks	Add Content-Security-Policy header
Missing Anti-clickjacking Header	Low	X-Frame-Options header is missing	Application may be vulnerable to clickjacking	Add X-Frame-Options header
X-Content-Type-Options Header Missing	Low	Browser MIME type protection not enabled	May allow content-type attacks	Set X-Content-Type-Options to "nosniff"

FIGURE 1: ABSENCE OF ANTI-CSRF TOKENS

Alerts (11)

Absence of Anti-CSRF Tokens (3)

Content Security Policy (CSP) Header Not Set (163)

Missing Anti-clickjacking Header (61)

Cookie without SameSite Attribute (2)

Cross-Domain JavaScript Source File Inclusion

Server Leaks Version Information via "Server" HTTP Response Header Field (205)

X-Content-Type-Options Header Missing (100)

ZAP is Out of Date

Information Disclosure - Suspicious Comments (10)

Modern Web Application (6)

Session Management Response Identified (2)

Absence of Anti-CSRF Tokens

URL: http://testfire.net/login.jsp

Risk: Medium

Confidence: Low

Parameter:

Attack:

Evidence: <form action="doLogin" method="post" name="login" id="login" onsubmit="return (confirminput(login));">

CWE ID: 352

WASC ID: 9

Source: Passive (10202 - Absence of Anti-CSRF Tokens)

Input Vector:

Description:

No Anti-CSRF tokens were found in a HTML submission form.

A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is

Other Info:

No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] was found in the following HTML form: [Form 2: "btnSubmit" "passw" "uid"].

Solution:

Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation.

Note that this can be bypassed using XSS.

Reference:

https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html

<https://cwe.mitre.org/data/definitions/352.html>

Alert Tags:

Key	Value
POLICY_PENTEST	
WSTG-v42-SESS-05	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Applicati...
OWASP_2017_A05	https://owasp.org/www-project-top-ten/2017/A5_2017-Broken_Access_Control...
CWE-352	https://cwe.mitre.org/data/definitions/352.html
POLICY_DEV_STD	

FIGURE 2: MISSING CONTENT SECURITY POLICY (CSP)

History

Search

Alerts

Output

Spider

Spider

Active Scan

Alerts (11)

> Absence of Anti-CSRF Tokens (3)

> Content Security Policy (CSP) Header Not Set (163)

> Missing Anti-clickjacking Header (61)

> Cookie without SameSite Attribute (2)

> Cross-Domain JavaScript Source File Inclusion

> Server Leaks Version Information via "Server" HTTP Response Header Field (205)

> X-Content-Type-Options Header Missing (100)

> ZAP is Out of Date

> Information Disclosure - Suspicious Comments (10)

> Modern Web Application (6)

> Session Management Response Identified (2)

Content Security Policy (CSP) Header Not Set

URL: http://testfire.net

Risk: Medium

Confidence: High

Parameter:

Attack:

Evidence:

CWE ID: 693

WASC ID: 15

Source: Passive (10038 - Content Security Policy (CSP) Header Not Set)

Alert Reference: 10038-1

Input Vector:

Description:

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript,

Other Info:

Solution:

Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

Reference:

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP>
https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
<https://www.w3.org/TR/CSP/>

Alert Tags:

Key	Value
CWE-693	https://cwe.mitre.org/data/definitions/693.html
OWASP_2021_A05	https://owasp.org/Top10/A05_2021-Security_Misconfiguration/
OWASP_2017_A06	https://owasp.org/www-project-top-ten/2017/A6_2017-Security_Misconfigurati...
POLICY_QA_STD	

FIGURE 3: COOKIE WITHOUT SAMESITE ATTRIBUTE

History

Search

Alerts

Output

Spider

AJAX Spider

Active Scan

Alerts (12)

Cross Site Scripting (Reflected)

Absence of Anti-CSRF Tokens (3)

Content Security Policy (CSP) Header Not Set (163)

Missing Anti-clickjacking Header (61)

Cookie without SameSite Attribute (2)

Cross-Domain JavaScript Source File Inclusion

Server Leaks Version Information via "Server" HTTP Response Header Field (205)

X-Content-Type-Options Header Missing (100)

ZAP is Out of Date

Information Disclosure - Suspicious Comments (10)

Modern Web Application (6)

Session Management Response Identified (2)

Cookie without SameSite Attribute

URL: http://testfire.net

Risk: Low

Confidence: Medium

Parameter: JSESSIONID

Attack:

Evidence: Set-Cookie: JSESSIONID

CWE ID: 1275

WASC ID: 13

Source: Passive (10054 - Cookie without SameSite Attribute)

Alert Reference: 10054-1

Input Vector:

Description:

A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.

Other Info:

Solution:

Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.

Reference:

<https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site>

Alert Tags:

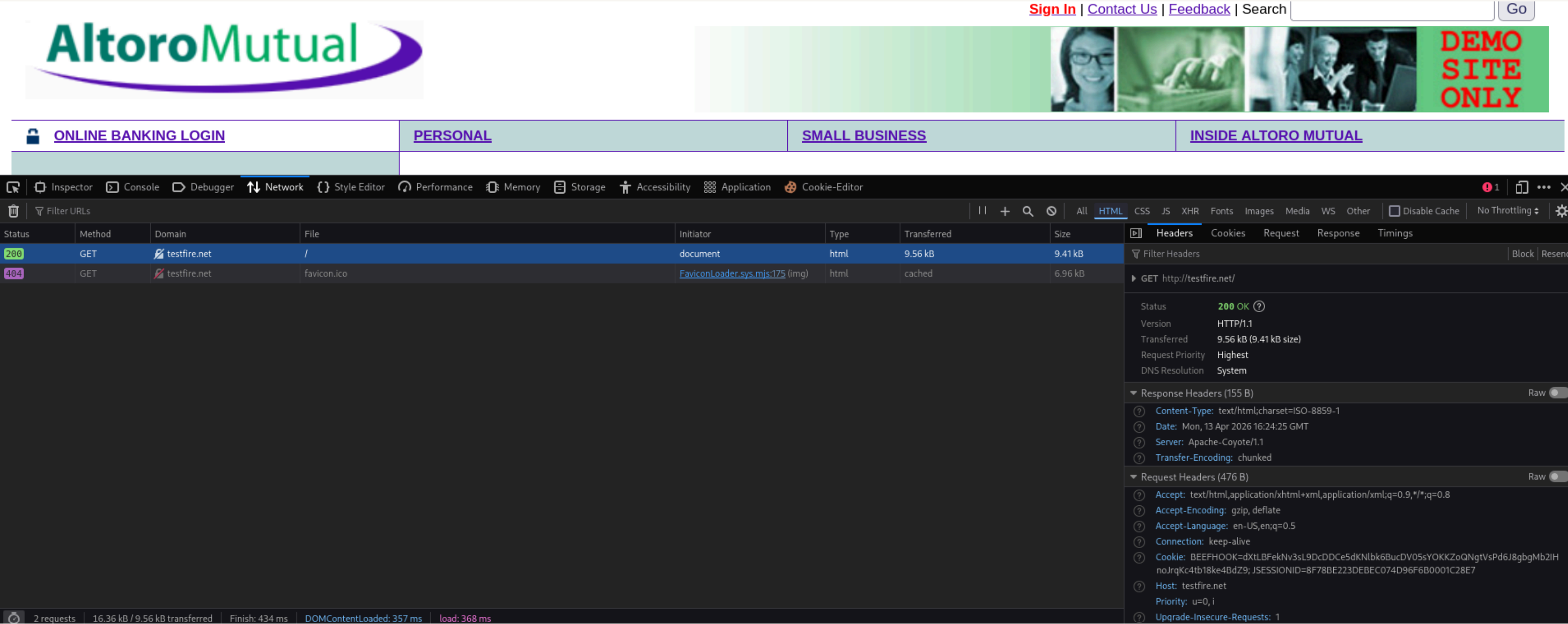
Key	Value
WSTG-v42-SESS-02	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Applicati...
POLICY_PENTEST	
CWE-1275	https://cwe.mitre.org/data/definitions/1275.html
OWASP_2017_A05	https://owasp.org/www-project-top-ten/2017/A5_2017-Broken_Access_Control...
POLICY_DEV_STD	

Security Configuration Analysis

(Browser DevTools)

FINDING	RISK LEVEL	DESCRIPTION	IMPACT	REMEDIATION
Missing Security Headers	Medium	Important headers like CSP and X-Frame-Options are not implemented	Increased risk of XSS and clickjacking attacks	Add CSP, X-Frame-Options, and X-Content-Type-Options headers
Insecure Cookie Configuration	Medium	Cookies lack Secure, HttpOnly, and SameSite attributes	Session hijacking and data exposure risks	Enable Secure, HttpOnly, and SameSite flags

FIGURE 1 : BROWSER DEVTOOLS SHOWING RESPONSE HEADERS AND COOKIE CONFIGURATION



Risk Summary

Vulnerability	Risk Level
Open HTTP Port	Medium
Server Information Disclosure	Low
Missing Content Security Policy	Medium
Absence of Anti-CSRF Tokens	Medium
Missing Anti-clickjacking Header	Low
Insecure Cookie Configuration	Medium

Conclusion

The vulnerability assessment identified several security weaknesses related to missing protections and configuration issues.

While no critical vulnerabilities were exploited, these issues may increase the risk of attacks if left unaddressed.

By implementing the recommended security measures, the overall security posture of the application can be significantly improved.

Recommendations

- Enforce HTTPS across the entire application
- Implement essential security headers
- Secure cookies using proper attributes
- Hide server information from responses
- Perform regular vulnerability assessments
- Follow secure coding practices